

LA CYBERSÉCURITÉ

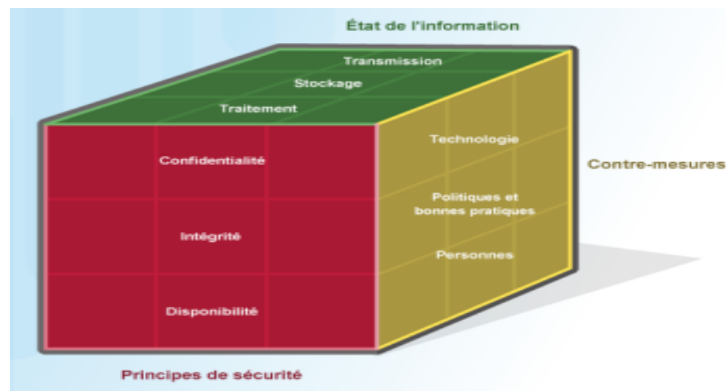
Sommaire :

1. Introduction
2. Les trois dimensions du cube magique
 - Principe de sécurité
 - Les états des données
 - Les contre-mesures en cybersécurité
3. Risque (définitions)
4. Exemples de Normes ISO
5. Méthodes de gestion des risques : EBIOS
6. PSSI (Politique de Sécurité des Systèmes d'Information)
7. Acteurs gouvernementaux de la cybersécurité en France
8. Conclusion

1. Introduction

La cybersécurité est un domaine essentiel dans un monde de plus en plus connecté et dépendant des technologies numériques. Elle vise à protéger les systèmes informatiques, les réseaux, les données et les utilisateurs contre les menaces telles que les cyberattaques, les accès non autorisés, les modifications malveillantes et les interruptions de service. Avec l'évolution rapide des technologies et l'émergence de nouvelles menaces (ransomware, phishing, attaques DDoS, etc.), la cybersécurité est devenue une priorité pour les organisations, les gouvernements et les individus. Ce cours explore les concepts fondamentaux, les méthodologies de gestion des risques, et les meilleures pratiques pour assurer une sécurité robuste et proactive.

2. Les trois dimensions du cube magique (Triade CIA)



Principes de sécurité :

Le "cube magique" de la cybersécurité repose sur trois principes fondamentaux, souvent appelés la **triade CIA** :

1. Confidentialité :

La confidentialité vise à garantir que seules les personnes autorisées peuvent accéder aux données. Cela inclut des techniques comme le chiffrement des données, les contrôles d'accès, et les politiques de gestion des identités.

Exemple : Le chiffrement des emails (via des protocoles comme PGP ou S/MIME) empêche les tiers non autorisés de lire les messages.

Enjeu actuel : Avec l'augmentation des attaques de type "man-in-the-middle", la confidentialité des communications est plus importante que jamais.

2. Intégrité :

L'intégrité assure que les données ne sont pas altérées de manière non autorisée. Des mécanismes comme les signatures numériques, les checksums (sommées de contrôle), et les journaux d'audit (logs) sont utilisés pour vérifier que les données n'ont pas été modifiées.

Exemple : Une signature numérique sur un document garantit que celui-ci n'a pas été modifié après sa création.

Enjeu actuel : Les attaques par ransomware ciblent souvent l'intégrité des données en les chiffrant et en demandant une rançon pour les restaurer.

3. Disponibilité (Availability) :

La disponibilité garantit que les systèmes et les données sont accessibles quand ils sont nécessaires. Cela implique des mesures comme la redondance des serveurs, les sauvegardes régulières, et la gestion des pannes.

Exemple : Les systèmes de sauvegarde en cloud permettent de restaurer rapidement les données en cas de panne ou d'attaque.

Enjeu actuel : Les attaques par déni de service distribué (DDoS) visent à rendre les services indisponibles, ce qui peut paralyser une organisation.

Les états des données :

Les données peuvent exister sous trois états, chacun nécessitant des mesures de protection spécifiques :

1. Données stockées :

Ce sont les données conservées sur des supports physiques (disques durs, serveurs, cloud, etc.).

Mesures de protection : Chiffrement des disques, contrôle d'accès physique et logique, et gestion des clés de chiffrement.

Exemple : Le chiffrement des bases de données protège les informations sensibles stockées contre les accès non autorisés.

Enjeu actuel : Les fuites de données (data breaches) sont de plus en plus fréquentes, notamment à cause de mauvaises configurations des systèmes de stockage cloud.

2. Données en transit :

Ces données circulent sur des réseaux (Internet, intranet, etc.) et sont vulnérables aux interceptions.

Mesures de protection : Protocoles sécurisés comme HTTPS, VPN, et chiffrement des communications (TLS/SSL).

Exemple : HTTPS protège les données échangées entre un navigateur et un serveur web.

Enjeu actuel : Les attaques de type "man-in-the-middle" ciblent souvent les données en transit, notamment sur les réseaux Wi-Fi publics.

3. Données en cours de traitement :

Ces données sont manipulées par des applications ou des utilisateurs et sont temporairement stockées dans la mémoire vive (RAM).

Mesures de protection : Isolation des processus, gestion sécurisée de la mémoire, et chiffrement en mémoire.

Exemple : Lors d'une transaction bancaire en ligne, les informations de carte de crédit sont traitées en mémoire vive avant d'être validées.

Enjeu actuel : Les attaques par "memory scraping" ciblent les données en cours de traitement pour voler des informations sensibles.

Les contre-mesures en cybersécurité :

Les contre-mesures sont des actions ou des dispositifs utilisés pour protéger les systèmes d'information. Elles se divisent en trois catégories :

1. Technologies :

- Redondance, Firewalls, antivirus, systèmes de détection d'intrusion (IDS)...etc.
- Chiffrement des données et des communications.

2. Politiques et bonnes pratiques :

- Utilisation de mots de passe forts et d'authentification multifactorielle.
- Mise en place de politiques de sécurité strictes.

3. Personnes :

- Formation des employés pour reconnaître les menaces (ex. : phishing).
- Sensibilisation aux bonnes pratiques de sécurité.

Enjeu actuel : Les attaques de phishing et d'ingénierie sociale ciblent souvent les employés, rendant la formation et la sensibilisation essentielles.

3. Risque : Définitions

En cybersécurité, un **risque** est la combinaison de la probabilité qu'une menace se réalise et de l'impact qu'elle pourrait avoir.

On peut décrire la fonction Risque comme ceci :

$$\text{Risque} = \text{Probabilité} \times \text{Impact} \times \text{Coût}$$

Probabilité (ou **vulnérabilité**) : Cela mesure la probabilité qu'une menace exploite avec succès une vulnérabilité dans votre système ou réseau. Plus la probabilité est élevée, plus le risque est important.

Impact (ou **menace**) : Cela représente l'ampleur des conséquences si une menace se matérialise. Cela peut inclure des pertes financières, des dommages à la réputation, des interruptions de service, etc. Un impact plus important entraîne généralement un risque plus élevé.

Coût (ou enjeu) : Cela représente les coûts potentiels associés à la réalisation du risque. Cela peut inclure des coûts de récupération après une attaque, des amendes réglementaires, des pertes de revenus, etc.

En multipliant ces trois facteurs ensemble, vous obtenez une estimation du niveau de risque associé à une menace spécifique. Cette formule permet aux organisations de mieux comprendre et de prioriser les mesures de sécurité en fonction des menaces les plus critiques et des risques les plus élevés.

Enjeu actuel : Les risques liés à la cybersécurité évoluent rapidement, notamment avec l'adoption de nouvelles technologies comme l'IA et l'IoT.

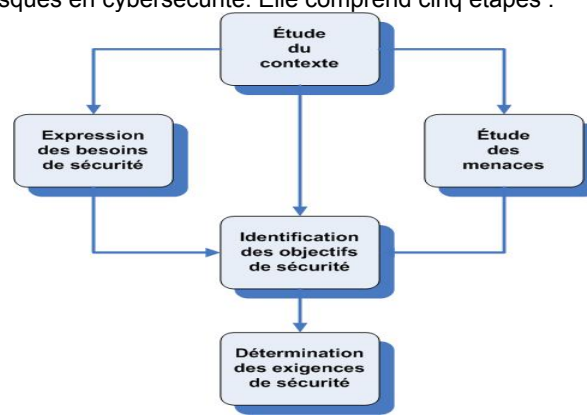
4. Exemples de Normes ISO

Les normes ISO fournissent des référentiels internationaux pour la gestion de la sécurité de l'information. Deux normes clés sont :

- **ISO/IEC 27001** :
Cette norme définit les exigences pour établir, mettre en œuvre, maintenir et améliorer un **Système de Management de la Sécurité de l'Information (SMSI)**. Elle aide les organisations à protéger leurs informations sensibles de manière structurée et à démontrer leur conformité aux régulateurs et aux clients.
- **ISO/IEC 27002** :
Cette norme fournit des lignes directrices pour la mise en œuvre des contrôles de sécurité. Elle propose des bonnes pratiques pour la gestion des risques, la protection des données, et la sécurité des réseaux. Elle est souvent utilisée en complément de l'ISO 27001.

5. Méthodes de gestion des risques : EBIOS

La méthode **EBIOS (Expression des Besoins et Identification des Objectifs de Sécurité)** est une approche structurée pour gérer les risques en cybersécurité. Elle comprend cinq étapes :



1. **Définir le contexte** : Identifier les ressources à protéger et les objectifs de sécurité.
2. **Analyser les risques** : Identifier les menaces, les vulnérabilités, et les impacts potentiels.
3. **Évaluer les risques** : Estimer la probabilité et la gravité des risques.
4. **Proposer des mesures** : Définir des actions pour réduire ou éliminer les risques.
5. **Contrôler l'efficacité** : Vérifier que les mesures mises en place sont efficaces et adaptées.

Enjeu actuel : Avec l'émergence de nouvelles menaces comme les attaques zero-day, les organisations doivent adopter des méthodes de gestion des risques dynamiques et réactives.

6. PSSI (Politique de Sécurité des Systèmes d'Information)

La **Politique de Sécurité des Systèmes d'Information (PSSI)** est un document stratégique qui définit les règles, procédures et bonnes pratiques pour protéger les systèmes d'information d'une organisation. Elle couvre :

- La protection des données sensibles.
- La gestion des accès et des identités.
- La prévention et la réponse aux incidents de sécurité.
- La conformité aux réglementations et normes (ex. : RGPD en Europe).

La PSSI sert de cadre pour assurer que tous les employés et systèmes respectent les mêmes standards de sécurité. Elle doit être régulièrement mise à jour pour s'adapter aux nouvelles menaces et aux évolutions technologiques.

7. Acteurs gouvernementaux de la cybersécurité en France :

Les principaux acteurs publics impliqués dans la cybersécurité en France sont :

- **ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information)** :
L'ANSSI est l'autorité nationale en matière de cybersécurité. Elle accompagne les organisations publiques et privées dans la sécurisation de leurs systèmes d'information.
- **CNIL (Commission Nationale de l'Informatique et des Libertés)** :
Chargée de protéger les données personnelles des citoyens français. Elle veille au respect du RGPD et fournit des recommandations en matière de protection des données.
- **Cybermalveillance.gouv.fr** :
Plateforme nationale d'assistance et de prévention des risques numériques. Elle sensibilise le grand public et les petites entreprises aux bonnes pratiques de cybersécurité.
- **DGE (Direction Générale des Entreprises)** :
Propose des initiatives pour renforcer la sécurité des entreprises françaises face aux cybermenaces.
- **Ministère des Armées (Commandement de la Cyberdéfense)** :
Il protège les infrastructures critiques nationales contre les cyberattaques et participe à des opérations de cybersécurité au niveau national et international.

- **CLUSIF (Club de la Sécurité de l'Information Français) :**

Association qui réunit des experts en cybersécurité pour promouvoir les bonnes pratiques et fournir des outils et méthodologies aux entreprises.

Ces entités jouent un rôle essentiel dans la protection des infrastructures critiques et dans la gestion des crises liées à la cybersécurité.

8. Conclusion

La cybersécurité est un enjeu majeur pour les organisations et les individus dans un monde de plus en plus numérique. En comprenant les concepts clés comme la triade CIA, les états des données, et les méthodes de gestion des risques, il est possible de mieux protéger les systèmes d'information. La mise en place de contre-mesures adaptées, l'adoption de normes ISO, et la formation des employés sont des étapes essentielles pour assurer une sécurité efficace et durable.

Enfin, la cybersécurité doit être vue comme un processus continu et évolutif, nécessitant une vigilance constante face aux nouvelles menaces et aux évolutions technologiques.

